

HUM 4747: Legal Issues and Cyber Law

Cyber Security and Cyber Law: Few Terminology

Aashnan Rahman

BSc in SWE
Islamic University of Technology (IUT)

Winter 2024-2025

Outline

- ① Fundamental Concepts
- ② Attacks and Malicious Software
- ③ Cyber Threat Defense

The protection of **digital devices** and their **communication channels** to keep them stable, dependable and reasonably safe from danger or threat. Usually the required protection level must be sufficient to prevent or address **unauthorized access** or before it can lead to substantial personal, professional, organizational, financial and/or political harm.

Any **electronic appliance** that can create, modify, archive, retrieve or transmit information in an **electronic format**. Desktop computers, laptops, tablets, smartphones and Internet-connected home devices are all examples of digital devices.

Any **traditional crime** that can happen using **ICT** can be regarded as a cyber-crime.

To take **aggressive or hostile action** by leveraging or targeting **digital devices**. The intended damage is not limited to the digital (electronic) environment.

Cyberwarfare is the use of **digital attacks** to attack a nation, causing comparable harm to actual warfare and/or disrupting the vital computer systems. Cyber warfare involves the actions by a **nation-state** or international organization to attack and attempt to damage another nation's computers or information networks through, for example, computer viruses or denial-of-service attacks.

The use of computer networks to gain **illicit access** to **confidential information**, typically that held by a government or other organization. Cyber espionage is a form of cyber-attack that steals **classified, sensitive data or intellectual property** to gain an advantage over a competitive company or government entity.

Suffering from a concern that weaknesses in your cybersecurity are going to cause one's personal or professional harm.

Hacker & Ethical Hacking

Hacker

A person who engages in attempts to gain **unauthorized access** to one or more digital devices.

Ethical Hacking

The process by which supportive (**white-hat**) testers assist in finding security weaknesses and vulnerabilities.

Red Team & Ethical Hacker

Red Team

When testing for potential exploits affecting any critical or sensitive system, infrastructure or website, a team of penetration testers is usually used. This term (red team) is used to describe the group of testers working together on this type of objective.

Ethical Hacker

An alternative name for a white hat tester.

A form of **malicious software** that spreads by **infecting** (attaching itself) to other files and usually seeks opportunities to continue that pattern. Viruses are now less common than other forms of malware. Viruses were the main type of malware in very early computing. For that reason, people often refer to something as a virus when it is technically another form of malware.

Shortened version of **malicious software**. A term used to describe the insertion of disruptive, subversive or hostile programs onto a digital device. These types of programs can be intentional or unintentional. Intentional versions are usually disguised or embedded in a file that looks harmless. There are many types of malware; **adware, botnets, computer viruses, ransomware, scareware, spyware, trojans and worms** are all examples of intentional malware. Hackers often use malware to mount cybersecurity attacks. (Software with malicious intention. i.e. Ransomware, third party apps to leak data)

Shortened version of **robotic network**. A connected set of programs designed to operate together over a network (including the Internet) to achieve specific purposes. The purpose can be good or bad. Some programs of this type are used to help support Internet connections; malicious uses include taking over control of some or all of a computer's functions to support large-scale service attacks (see denial of service). Botnets are sometimes referred to as a **zombie army**.

A form of malicious software (malware) that prevents or restricts usage of one or more digital devices or applications or renders a collection of electronic data unreadable until a **sum of money is paid**. [It simulates traditional ransom. For example, **WannaCry (2017)**]

A form of malware that **covertly gathers and transmits information** from the device on which it is installed. Example: **Pegasus**

Using an electronic communication (for example email or instant messaging) that pretends to come from a **legitimate source**, in an attempt to get **sensitive information** (for example, a password or credit card number) from the recipient or to install malware on the recipient's device. The methods used in phishing have evolved so that the message can simply contain a link to an Internet location where malware is situated or can include an attachment (such as a PDF or Word document) that installs malware when opened.

A more **targeted form of phishing**. This term describes the use of an electronic communication (for example, email or instant messaging) that targets a **particular person or group** of people (for example, employees at a location) and pretends to come from a legitimate source. In this case, the source may also pretend to be someone known and trusted to the recipient, in an attempt to obtain sensitive information (for example, a password or credit card number).

Concealing the true source of electronic information by impersonation or other means. Often used to bypass Internet security filters by pretending the source is from a trusted location.

Social Engineering Attack

It is the art of manipulating people through personal interaction to gain unauthorized access to something. The act of constructing relationships, friendships or other human interactions for the purpose of enticing the recipient to perform an action or reveal information.

Denial of Service (DoS)

An attack designed to stop or disrupt peoples' use of organizations' systems. Usually, a particular section of an enterprise is targeted. If the attack is from multiple source locations, it is referred to as a Distributed Denial of Service, or DDoS attack.

Vulnerability, Vector, Exploit

Vulnerability

(in the context of cybersecurity) a weakness that could be compromised and result in damage or harm.

Vector

another word for 'method' – as in 'They used multiple vectors for the attack.'

Exploit

To take advantage of a security vulnerability.

Zero-day & Backdoor

Zero-day

It refers to the very first time a new type of exploit or new piece of malware is discovered. At that point in time, none of the anti-virus, anti-malware or other defenses may be set up to defend against the new form of exploit.

Backdoor

A covert method of accessing software or a device that bypasses the normal authentication requirements.

Threat Actors

An umbrella term to describe the collection of people and organizations that work to create cyber-attacks. Examples of threat actors can include cyber criminals, hacktivists and nation states.

It is a computer program designed to look for specific files and behaviors (signatures) that indicate the presence or the attempted installation of malicious software. If or when detected, the program seeks to isolate the attack (quarantine or block the malware), remove it, if it can, and also alert appropriate people to the attempt or to the presence of the malware.

Signatures (in the context of cybersecurity) are the unique attributes – for example, file size, file extension, data usage patterns and method of operation – that identify a specific computer program. Traditional anti- malware and other security technologies can make use of this information to identify and manage some forms of rogue software or communications.

Defense in Depth

The use of multiple layers of security techniques to help reduce the chance of a successful attack. The idea is that if one security technique fails or is bypassed, there are others that should address the attack. The latest (and correct) thinking on defense in depth is that security techniques must also consider people and operations (for example processes) factors and not just technology.

A prepared set of processes that should be triggered when any known or suspected event takes place that could cause material damage to an organization. The typical stages are (i) verify the event is real and identify the affected areas, (ii) contain the problem, (iii) understand and eradicate the root cause, (iv) restore the affected components to their fixed state and (v) review how the process went to identify improvements.

Breach Notification Procedure

Some types of information, when suspected or known to be lost or stolen, must, by law, be reported to one or more authorities within a defined time period. The required notification time period varies by regulator, but is often within 24 hours.

Secure Configuration

It is a process ensuring that when settings are applied to any item (device or software), appropriate steps are always taken to ensure (i) default accounts are removed or disabled, (ii) shared accounts are not used and (iii) all protective and defensive controls in the item use the strongest appropriate setting(s).

Penetration Test (Pen. Test)

Checks and scans on any application, system or website to identify any potential security gaps (vulnerabilities) that could be exploited. Once the vulnerabilities are identified, this process then goes on to identify the extent to which these vulnerabilities could be leveraged in an attack.

The identification and classification of security gaps in a computer, software application, network or other section of a digital landscape. This is usually a passive identification technique that aims only to identify the gaps, without exploring how those gaps could be used in an attack.

Business Continuity Plan (BCP)

An operational document that describes how an organization can restore its critical products or services to its customers, should a substantial event that causes disruption to normal operations occur.

Technical Disaster Recovery Plan

An operational document that describes the exact process, people, information and assets required to put any electronic or digital system back in place within a timeline defined by the business continuity plan.

Patch Management

A controlled process used to deploy critical, interim updates to software on digital devices. The release of a software 'patch' is usually in response to a critical flaw or gap that has been identified. Promptly applying these updates is considered a critical component of maintaining effective cybersecurity.

The art of examining ciphered information to determine how to circumvent the technique that was used to encode or hide it. Analyzing ciphers.

Firewall

It is hardware (physical device) or software (computer program) used to monitor and protect inbound and outbound data (electronic information). It achieves this by applying a set of rules. These are usually deployed at the perimeter of each network access point.

Chief Information Security Officer (CISO)

A single point of accountability in any organization for ensuring that an appropriate framework for managing dangers and threats to electronic and physical information assets is operating and effective.

Policy

A high-level statement of intent that provides guidance on the principles an organization follows.

Procedure

Provides guidance or specific instruction on the process (method) that should be used to achieve an objective.

A situation involving exposure to significant impact or loss. In formal frameworks, risk can be quantified using probability and impact.

Term	Definition	Simple Example
Phishing	A scam where attackers send fraudulent emails pretending to be from legitimate sources to trick users into revealing sensitive information.	An email from a fake bank asking you to click a link and enter your login details.
Spear Phishing	A targeted phishing attack aimed at a specific individual or organization, using personalized information.	An email to a company employee using their name and job title, pretending to be from HR with a malicious attachment.
Spoofing	Faking the sender's identity in communications (e.g., email or IP spoofing).	An email that appears to come from your boss but is actually from an attacker, asking for sensitive files.
Pharming	Redirecting users from legitimate websites to fraudulent ones, often via DNS poisoning.	Altering DNS settings so typing "bank.com" leads to a fake site that steals your credentials.

Types of Hackers: The “Hat” System

Hat Type	Definition	Example
White Hat	Ethical hackers who test systems with permission to improve security.	A cybersecurity expert hired by a company to perform penetration testing.
Black Hat	Malicious hackers who exploit vulnerabilities for personal gain or harm, illegally.	A criminal stealing credit card data from a website for financial fraud.
Gray Hat	Hackers who find vulnerabilities without permission but may report them (ethically ambiguous).	Someone who hacks a system, discovers a flaw, and notifies the owner without exploiting it fully.
Red Hat	Vigilante hackers who aggressively target black hat hackers, often using similar tactics.	A hacker who launches counter-attacks against cybercriminals to disrupt their operations.
Blue Hat	Outside hackers invited by companies (e.g., Microsoft) to test products before release; or revenge-seeking hackers.	Microsoft inviting experts to a “BlueHat” conference to find bugs in software.
Green Hat	Novice hackers eager to learn and improve their skills, aspiring to become pros.	A beginner studying ethical hacking tutorials to eventually work in cybersecurity.
Script Kiddie	Unskilled amateurs who use pre-made tools/scripts without understanding them.	A teen using downloaded malware to deface a website for fun, without coding knowledge.